Departamento de Lenguajes y Sistemas Informáticos
E.T.S. Ingeniería Informática. Universidad de Sevilla

Avda Reina Mercedes s/n. 41012 Sevilla
Tlf/Fax 954 557 139 **E-mail** lsi@lsi.us.es **Web** www.lsi.us.es

E.T.S. ingeniería informática

SEGURIDAD EN SISTEMAS INFORMÁTICOS Y EN INTERNET

CAI 3. CONSULTA SOBRE LA IDENTIFICACIÓN, AUTENTICACIÓN Y AUTORIZACIÓN EN UNA ENTIDAD HOSPITALARIA (Parte 1)

Debido a que se han detectado incidencias en los accesos de los usuarios a determinados servicios, nuestro cliente el Hospital desea mejorar su sistema de acceso a servicios. Para ello se ha pensado en añadir una capa de autenticación TOTP a un sistema de inicio de sesión existente. TOTP es un tipo de 2FA que genera códigos numéricos únicos basados en un secreto compartido y la hora actual, por lo que van cambiando periódicamente. Se desea utilizar la App **FreeOTP,** que sería instalada en los teléfonos móviles. Una aplicación OTP (One-Time Password) genera contraseñas de un solo uso que se utilizan como un segundo factor de autenticación para mejorar la seguridad. Además para segmentar la información por roles, se ha pensado en utilizar Oauth2 para el acceso a los servicios.

Desde la entidad Hospitalaria han desarrollado un prototipo (Python), nos requieren para mejorarla desde el punto de vista de la Ciberseguridad. El portal médico dividido en dos microservicios:

1. Servidor de Identidad (Authorization Server): que gestiona usuarios, controla el MFA con FreeOTP y la emisión de tokens.
2. Portal Médico (Cliente OAuth2 y API): Interfaz web y endpoints.

Para poder hacer pruebas se han incluido dos perfiles registrados de pruebas:
• Rocio: Paciente (tiene acceso a sus historia clínica)
• Dr Gasca: Médico (puede modificar historias clínicas)

Apartado a). Perspectiva Red Team (Explotación). Analizar la arquitectura y demostrar fallos de control de acceso, gestión de tokens y autenticación sin alterar el código fuente. Por ejemplo se han observado los siguientes problemas (puede incluir mas ejemplos en el informe):

- Escalada de privilegios en la API
- Exposición del token en el navegador

Revisa el flujo de autorización entre el puerto 8001 y el 8000. ¿Se está utilizando el parámetro code_challenge (PKCE) durante la redirección? ¿Qué riesgo supone su ausencia si un atacante intercepta el code temporal en /callback?.

Apartado b). Perspectiva Blue Team (Hardening). Modificar el código de ambos servidores (8000 y 8001) y las plantillas HTML para mitigar todas las vulnerabilidades detectadas. Vulnerabilidades inicialmente detectadas (puede solucionar más vulnerabilidades si lo cree necesario):

- Corregir el control de permisos/roles en la API
- Blindar el almacenamiento del JWT
- Activar PKCE obligatorio y autenticación de cliente confidencial

- Eliminar la exposición de claves y secretos

Apartado c). Recomendaciones para el Hospital. Desde el Hospital nos piden un proyecto con las modificaciones sugeridas en formato .zip para poder hacer pruebas.

Nota. Entrega el proyecto a evaluar en formato zip. Las principales librerías utilizadas son:

- Flask: Se encarga de levantar el servidor HTTP, gestionar las rutas (/oauth/authorize, /oauth/token, etc.), procesar los formularios (request) y devolver las respuestas en HTML o JSON.
- Authlib: Es el núcleo de todo el sistema OAuth 2.0. Implementa el servidor de autorización, los flujos de concesión, y la creación/firma de los tokens JWT.
- Passlib: Es una librería especializada en algoritmos de resumen seguro de contraseñas. Se usa para configurar el algoritmo Argon2, generar el hash de la contraseña y verificarla durante la autenticación.
- PyOTP: Implementa el estándar TOTP (contraseñas de un solo uso basadas en el tiempo) para el doble factor de autenticación (2FA). Genera la semilla secreta, crea la URI de configuración y valida los códigos de 6 dígitos que introduce el usuario.
- QRCode: Se encarga de transformar la URI generada por PyOTP en una imagen de código QR. Permite incrustar la imagen directamente en la plantilla HTML para que el usuario la escanee con su móvil.

Normas del entregable

- Cada ***Security Team X*** debe entregar el informe ST-X-CAI3-Parte1.pdf que contenga todos los detalles que responden a los puntos de la consultoría (se debe indicar expresamente los alumnos del equipo que han participado en el trabajo) a través de la actividad creada al efecto en el curso de Enseñanza Virtual. El informe debe recoger evidencias del proceso, herramientas, código y pruebas realizadas, así como las respuestas a las consultas planteadas. Debe entregarse también el proyecto desarrollado (puede entregarse un zip que incluya también el informe).
- La consulta se desarrollará en la sesión dispuesta al efecto, y en el tiempo indicado por el profesor.
- Para centrar todo el esfuerzo en los mecanismos de ciberseguridad **queda fuera del alcance de esta práctica** (y no se evaluará) lo siguiente:
    - **Bases de datos reales ni contenedores:** Utiliza estructuras en memoria (diccionarios o listas en Python) para guardar usuarios, códigos y tokens.
    - **Gestión de usuarios, registro o recuperación de cuentas**. Basta con dejar uno o dos usuarios predefinidos al arrancar el servidor.
    - El diseño visual (CSS) no forma parte de la evaluación.
    - **Gestores de secretos externos ni rotación automática de claves (Vault, AWS KMS)**
    - **Sistemas de monitorización externa (SIEM, ELK, logs forenses complejos):** No hace falta integrar servidores de logs externos ni sistemas WAF perimetrales